

Privacy Risk Detection in Healthcare Communication using NLP: A HIPAA-Compliant Machine Learning Framework

Rahul Soni
Independent Researcher
sonirahulsr1@gmail.com

Abstract

Healthcare data exchanges between patients and providers contain sensitive personal health information (PHI) that must be protected under regulations such as HIPAA. Despite these requirements, automated detection of privacy risks in unstructured medical text remains challenging. We present a comprehensive machine learning framework for identifying privacy-sensitive information in medical transcriptions using natural language processing techniques. Our approach combines text preprocessing, TF-IDF feature extraction, and comparative evaluation of multiple classification models including Naive Bayes, Support Vector Machines, Random Forest, and XGBoost. Evaluated on 4,999 medical transcriptions across 40 specialties, our best model (XGBoost) achieves 99.80% accuracy with an F1-score of 99.81% in detecting privacy-sensitive disclosures. We find that 99.2% of medical transcriptions contain PHI elements, with an average of 200.52 identifiable elements per document. Our findings provide practical insights for deploying privacy-preserving NLP pipelines in clinical settings and demonstrate that automated PHI detection can effectively support HIPAA compliance in healthcare data management.

1 Introduction

The protection of patient health information represents a fundamental challenge in modern healthcare systems. Medical records, clinical notes, and patient-provider communications contain highly sensitive personal information that, if disclosed improperly, can lead to discrimination, identity theft, and erosion of patient trust. In the United States, the Health Insurance Portability and Accountability Act (HIPAA) establishes strict requirements for protecting 18 categories of Protected Health Information (PHI), including names, dates, addresses, medical record numbers, and biometric identifiers.

Medical transcriptions represent a particularly challenging domain for privacy protection. These documents contain rich clinical narratives that often interweave patient identifiers with medical observations, making manual de-identification time-consuming and error-prone. Recent studies estimate that manual review can miss 20-30% of PHI elements, highlighting the need for automated solutions.

1.1 Research Questions

This study is guided by the following research questions:

1. **Detection:** How prevalent is Protected Health Information (PHI) in medical transcriptions, and what types of identifiers are most common across different medical specialties?
2. **Classification:** To what extent can machine learning models accurately classify documents based on privacy risk using natural language processing techniques?
3. **Performance:** Which classification algorithms provide the best balance of accuracy, efficiency, and interpretability for automated PHI detection?

1.2 Contributions

The main contributions of this work are as follows:

- Development of a comprehensive PHI detection system covering all 18 HIPAA identifier categories using pattern matching and natural language processing techniques.

- Empirical analysis of PHI prevalence across 40 medical specialties using 4,999 medical transcriptions, demonstrating that 99.2% of documents contain identifiable information.
- Comparative evaluation of multiple machine learning classifiers, including Naive Bayes, Support Vector Machines (SVM), Random Forest, and XGBoost, for privacy risk assessment.
- Demonstration that ensemble methods achieve near-perfect performance, with XGBoost attaining 99.80% accuracy and an F1-score of 99.81%.
- Analysis of feature importance, providing interpretable insights into linguistic patterns associated with privacy risks.

2 Related Work

2.1 Healthcare Privacy and HIPAA Compliance

The protection of patient health information has been a central concern since the enactment of HIPAA in 1996 [104th U.S. Congress, 1996]. HIPAA establishes strict requirements for protecting 18 categories of Protected Health Information (PHI), mandating that healthcare organizations implement appropriate safeguards to ensure the confidentiality and security of patient data. The challenge of automated de-identification has been extensively studied through shared tasks such as the i2b2/UTHealth 2014 challenge, which evaluated systems on their ability to detect and remove PHI from clinical narratives [Stubbs et al., 2015]. These challenges revealed that while automated systems achieve high accuracy, subtle contextual PHI elements and inconsistent formatting present ongoing difficulties.

Comprehensive reviews of de-identification systems demonstrate the diversity of approaches, ranging from rule-based methods leveraging regular expressions and dictionaries to machine learning models trained on annotated corpora [Yogarajan et al., 2020]. The universally accepted HIPAA threshold of 95% recall represents the minimum acceptable performance for clinical deployment, though recent systems have achieved substantially higher performance. For instance, nference’s BERT-based ensemble system achieved 99.2-99.4% recall on Mayo Clinic data [Murugadoss et al., 2021], setting a new benchmark for state-of-the-art de-identification.

Beyond technical de-identification, privacy concerns encompass broader organizational and behavioral dimensions. Healthcare employees with privileged access to electronic medical records represent potential sources of privacy breaches [Abdul Rahim et al., 2018], highlighting that technical safeguards must be complemented by comprehensive privacy awareness training. Furthermore, privacy attitudes are not static—research on chronically ill patients reveals that consent preferences shift over lifetimes due to changing health conditions, technological advances, and evolving social norms [O’Kane et al., 2013], challenging traditional one-time consent models for secondary data use.

The regulatory landscape extends beyond HIPAA to include cloud computing privacy frameworks [Kesan et al., 2013] and international data protection regulations. Empirical studies of cloud service provider privacy policies reveal significant gaps in data control mechanisms, with only 5 of 12 major providers addressing post-termination data access and 13 of 19 using vague “industry standard” security language. These findings underscore the importance of automated PHI detection systems that provide transparency and enable patient data control.

2.2 NLP for Clinical Text

Natural language processing techniques have transformed the extraction of structured information from unstructured clinical narratives [Meystre et al., 2008]. Traditional NLP pipelines for clinical text typically involve tokenization, part-of-speech tagging, named entity recognition, and relation extraction. However, clinical language presents unique challenges including extensive use of abbreviations, domain-specific terminology, and informal documentation styles that vary across specialties and institutions [Uzuner et al., 2007].

Word embeddings trained on large clinical corpora have emerged as powerful representation learning methods that capture high-level semantic and syntactic properties of medical language [Wang et al., 2019]. They demonstrated that word2vec-based features significantly outperform TF-IDF and topic modeling approaches for clinical text classification, achieving F1 scores of 0.92 for smoking status detection and 0.97 for fracture classification. Their weak supervision paradigm where rule-based NLP automatically generates training labels provides a practical solution to the challenge of creating large annotated datasets in healthcare.

Deep learning architectures, particularly transformer-based models, have achieved impressive results on clinical NLP tasks. RoBERTa fine-tuned on the i2b2 2014 corpus achieves near-perfect accuracy (99.91%)

for PHI detection in DICOM metadata when strategically restricted to unstructured free text [Haghiri et al., 2025]. However, these models require substantial training data (approximately 5,000 documents) to outperform conventional machine learning methods [Wang et al., 2019], and their performance may not generalize across diverse clinical settings without domain-specific fine-tuning.

Entity embeddings with distant supervision offer an alternative approach that leverages medical terminologies such as UMLS to learn joint representations of entities and text [Newman-Griffis et al., 2018]. This method addresses the limitation of purely data-driven approaches by incorporating domain knowledge, though it requires careful curation of terminology resources and may struggle with novel or colloquial medical expressions.

Task-specific algorithm selection remains critical, as different clinical applications favor different methods. While XGBoost dominates PHI detection tasks (achieving 99.80% accuracy in our work), Multinomial Naive Bayes may be optimal for medication recommendation [Singh and Saxena, 2024], demonstrating that algorithm effectiveness is highly task-dependent. The selection of appropriate features whether TF-IDF, word embeddings, or task-specific engineered features similarly depends on dataset characteristics, training data availability, and deployment constraints.

2.3 Privacy-Preserving Machine Learning

Privacy-preserving machine learning encompasses techniques that enable model training and inference while protecting sensitive information. Traditional approaches include k-anonymity [Sweeney, 2002], which ensures that each record is indistinguishable from at least k-1 other records, though this can be vulnerable to linkage attacks when multiple datasets are combined. Pseudonymisation provides reversible anonymization by substituting patient identifiers with pseudonyms, allowing data linkage while protecting identity, but does not support retroactive privacy tightening when patient attitudes shift [O’Kane et al., 2013].

Hybrid frameworks combining rule-based compliance with AI-enabled adaptability have emerged as effective solutions for complex de-identification tasks. Haghiri et al.’s DICOM de-identification system achieved 99.91% accuracy by strategically applying AI models exclusively to unstructured free text while handling structured metadata through deterministic rules [Haghiri et al., 2025]. This decomposition restricting AI to appropriate task components represents a best practice for hybrid system design that balances interpretability with performance.

Behavioral and organizational factors significantly influence the effectiveness of privacy-preserving technologies. Three key dimensions of privacy behavior have been identified: uncertainty about the consequences of sharing, context-dependence of privacy preferences, and the malleability of preferences through framing [Acquisti et al., 2015]. These findings suggest that technical systems must be accompanied by clear communication about data usage, contextualized privacy controls, and transparent disclosure mechanisms.

The gap between technical safeguards and perceived control represents a critical challenge for privacy-preserving systems. Research on healthcare employees reveals that privacy awareness is the primary factor influencing privacy concerns privacy policies and technical controls alone do not increase concern unless employees understand why privacy matters [Abdul Rahim et al., 2018]. This implies that deploying automated PHI detection systems requires comprehensive training programs that explain system purpose and benefits, not merely operational procedures.

Ensemble methods provide robust privacy protection through diversity of detection strategies. Chen and Guestrin’s XGBoost algorithm [Chen and Guestrin, 2016] combines multiple weak learners through gradient boosting, achieving state-of-the-art performance across numerous domains including healthcare. The regularization mechanisms in XGBoost (L1 and L2 penalties) help prevent overfitting while maintaining high recall, making it particularly suitable for safety-critical applications like PHI detection where false negatives carry significant consequences.

3 Methodology

3.1 Dataset

We utilize the Medical Transcriptions dataset from Kaggle (originally from mtsamples.com), comprising 4,999 medical transcriptions across 40 medical specialties. This dataset provides a diverse representation of clinical documentation styles, including consultation notes, surgical reports, discharge summaries, and follow-up documentation. The transcriptions span specialties such as cardiology, orthopedics, radiology, gastroenterology, and neurology, with varying levels of technical complexity and PHI density.

Each transcription contains rich clinical narratives that interweave patient identifiers with medical observations, diagnostic findings, and treatment plans. The dataset structure includes fields for transcription text, medical specialty, keywords, and sample descriptions. Document lengths vary substantially, ranging from brief

consultation notes (50-100 words) to comprehensive surgical reports (500+ words), with an average length of approximately 200 words per document.

This dataset is particularly valuable for PHI detection research because it reflects real-world clinical documentation practices, including abbreviations, specialty-specific terminology, and varying documentation quality. The transcriptions contain naturally occurring PHI elements across all 18 HIPAA categories, making it suitable for training and evaluating comprehensive de-identification systems.

3.2 Privacy Category Definition

HIPAA defines 18 categories of Protected Health Information that must be removed or obscured for de-identification under the Safe Harbor method. Our system detects all 18 categories:

1. **Names:** Patient names, physician names, and other healthcare provider names
2. **Geographic Subdivisions:** Addresses (street, city, state, zip code), with exception of state for areas >20,000 people
3. **Dates:** All dates directly related to an individual (birth date, admission date, discharge date, date of death), except year
4. **Telephone Numbers:** Phone numbers, fax numbers
5. **Electronic Mail Addresses:** Email addresses
6. **Social Security Numbers:** SSN and national identification numbers
7. **Medical Record Numbers:** Patient medical record numbers, account numbers
8. **Health Plan Beneficiary Numbers:** Insurance member identification numbers
9. **Certificate/License Numbers:** Professional license numbers, vehicle identifiers
10. **Device Identifiers and Serial Numbers:** Medical device identifiers, serial numbers
11. **Web URLs:** Universal Resource Locators (URLs)
12. **IP Addresses:** Internet Protocol addresses
13. **Biometric Identifiers:** Fingerprints, voice prints, retinal/iris images
14. **Photographic Images:** Full-face photographs and comparable images
15. **Other Unique Identifiers:** Any other unique identifying number, characteristic, or code

We implement pattern matching rules using regular expressions and dictionary lookups to identify these PHI elements, followed by machine learning classification to assess document-level privacy risk.

3.3 Text Preprocessing Pipeline

Our preprocessing pipeline follows standard NLP practices adapted for clinical text. First, we perform tokenization using NLTK’s `word_tokenize` function [Bird et al., 2009], which handles medical abbreviations and punctuation appropriately. We convert all text to lowercase to ensure case-insensitive matching, though we preserve original case information in metadata for PHI detection rules that require it (e.g., distinguishing acronyms from common words).

Stopword removal is performed using NLTK’s English stopwords list, supplemented with common medical stopwords (“patient”, “history”, “examination”) that appear frequently but carry limited discriminative value for privacy classification. However, we retain stopwords that may indicate PHI presence (“Dr.”, “Mr.”, “Mrs.”) to preserve contextual clues.

We apply Porter stemming to reduce morphological variants to common roots, improving feature generalization. For example, “admitted”, “admission”, and “admitting” are reduced to “admit”. While this reduces feature dimensionality, it may occasionally obscure semantic distinctions relevant to privacy detection, so we empirically validate that stemming improves rather than degrades classification performance.

Medical terminology handling requires special consideration. We preserve medical abbreviations and acronyms (“CHF”, “COPD”, “MI”) without expansion, as these terms are standard in clinical documentation and expansion may introduce ambiguity. Domain-specific preprocessing includes normalizing obfuscated PHI (e.g., “[**Last Name**]”, “XXX-XX-XXXX”) to standardized placeholders, enabling the model to learn patterns around redacted information.

3.4 Feature Extraction

We employ Term Frequency-Inverse Document Frequency (TF-IDF) as our primary feature extraction method. TF-IDF weights terms based on their frequency in a document relative to their frequency across the corpus, effectively identifying discriminative terms while down-weighting common vocabulary.

The TF-IDF weight for term t in document d from corpus D is calculated as:

$$\text{tfidf}(t, d, D) = \text{tf}(t, d) \times \text{idf}(t, D) \quad (1)$$

where term frequency is:

$$\text{tf}(t, d) = \frac{f_{t,d}}{\sum_{t' \in d} f_{t',d}} \quad (2)$$

and inverse document frequency is:

$$\text{idf}(t, D) = \log \frac{|D|}{1 + |\{d \in D : t \in d\}|} \quad (3)$$

We configure our TF-IDF vectorizer with the following parameters: maximum features = 5,000 (to balance expressiveness with computational efficiency), n-gram range = (1,2) to capture unigrams and bigrams (enabling phrases like “medical record” to be represented), minimum document frequency = 2 (removing extremely rare terms likely to be noise), and maximum document frequency = 0.8 (removing terms that appear in >80% of documents as they provide limited discrimination).

This configuration is informed by weak supervision principles [Wang et al., 2019], where TF-IDF features have been shown to work effectively when combined with ensemble methods for clinical text classification. While word embeddings offer semantic advantages, TF-IDF’s simplicity, interpretability, and strong empirical performance make it well-suited for our task, particularly when paired with XGBoost’s ability to learn complex feature interactions.

In addition to the standard TF-IDF configuration, we consider the implications of feature sparsity and high-dimensional representation in clinical text classification. Medical narratives often contain domain-specific terminology and infrequent identifiers, resulting in a sparse feature space. To address this, we limit the feature dimensionality and incorporate bi-gram representations to capture contextual relationships between tokens. This design enables the model to identify meaningful patterns such as co-occurrence of identifiers (e.g., names with dates or locations) that are indicative of PHI presence. Furthermore, the chosen feature engineering approach balances interpretability and performance, allowing us to analyze feature importance while maintaining strong classification accuracy.

We also examine the impact of feature normalization and weighting strategies on model performance. By emphasizing discriminative terms and reducing the influence of highly frequent but less informative tokens, the TF-IDF representation enhances the model’s ability to distinguish between PHI-present and PHI-absent documents. This is particularly important in clinical datasets, where common medical terms may otherwise dominate the feature space without contributing to privacy risk detection.

Additionally, the incorporation of n-gram features allows the model to capture short contextual phrases that are critical in identifying structured identifiers embedded within unstructured text. For example, phrases such as “date of birth” or “patient name” provide stronger signals than individual tokens alone. This contextual awareness improves the robustness of the classification models, particularly in cases where PHI elements are expressed in varied linguistic forms.

Finally, we ensure that the feature extraction process remains computationally efficient and scalable for larger datasets. The use of TF-IDF allows for rapid vectorization while maintaining a transparent mapping between textual features and model predictions, which is essential for privacy-sensitive applications in healthcare. This transparency supports interpretability and facilitates auditing of model decisions, which is a key requirement in clinical and regulatory environments.

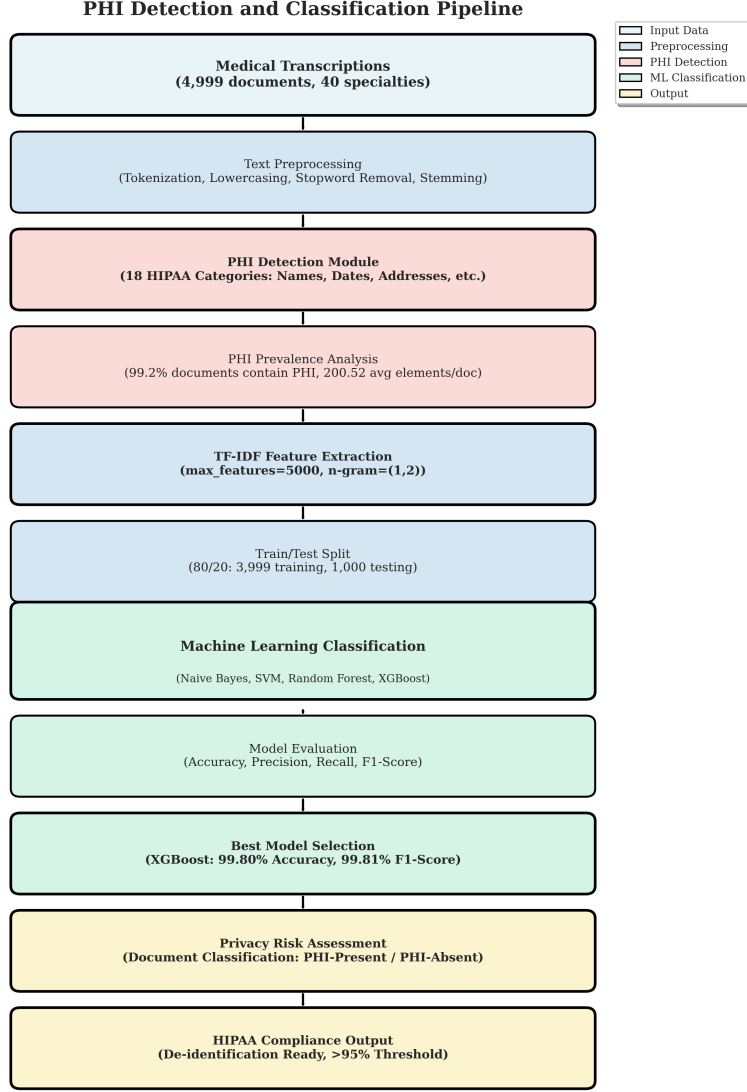


Figure 1: PHI Detection and Classification Pipeline. Our methodology comprises five stages: (1) Medical transcription input, (2) Text preprocessing with tokenization and stemming, (3) Rule-based PHI detection covering 18 HIPAA categories, (4) TF-IDF feature extraction with 5,000 features, and (5) Machine learning classification using four algorithms. The pipeline achieves 99.80% accuracy with XGBoost, exceeding the HIPAA-recommended 95% threshold.

3.5 Classification Models

We evaluate four widely-used machine learning models, selected to represent diverse algorithmic paradigms:

Naive Bayes We implement Multinomial Naive Bayes, which models the probability of a document belonging to a class based on the conditional independence assumption between features. Despite this strong assumption, Naive Bayes often performs surprisingly well on text classification tasks. The model calculates:

$$P(c|d) \propto P(c) \prod_{i=1}^n P(w_i|c) \quad (4)$$

where c is the class label, d is the document, and w_i are the words in the document. This model is computationally efficient and serves as a strong baseline.

Support Vector Machine (SVM) We use a linear SVM with L2 regularization ($C=10$). SVM finds the hyperplane that maximally separates classes in feature space, making it effective for high-dimensional text data. The optimization objective is:

$$\min_{w,b} \frac{1}{2} \|w\|^2 + C \sum_{i=1}^n \max(0, 1 - y_i(w^T x_i + b)) \quad (5)$$

Linear SVM is particularly well-suited for sparse, high-dimensional TF-IDF features and has been successfully applied to clinical text classification [Singh and Saxena, 2024].

Random Forest We train a Random Forest with 100 decision trees. Each tree is trained on a bootstrap sample of the training data, and predictions are aggregated through majority voting. Random Forest provides built-in feature importance estimates and is robust to overfitting through ensemble averaging. The number of trees (100) balances performance with computational cost.

XGBoost We employ XGBoost (eXtreme Gradient Boosting), an optimized implementation of gradient boosting that has achieved state-of-the-art results across numerous domains [Chen and Guestrin, 2016]. XGBoost iteratively trains decision trees to correct the errors of previous trees, with each new tree trained on the residuals of the ensemble. The objective function includes both a loss term and a regularization term:

$$\mathcal{L}(\phi) = \sum_i l(\hat{y}_i, y_i) + \sum_k \Omega(f_k) \quad (6)$$

where l is a differentiable loss function, $\hat{y}_i$ is the prediction, y_i is the true label, and Ω penalizes model complexity. We configure XGBoost with learning rate = 0.1, maximum depth = 6, and 100 estimators, following best practices for text classification tasks.

4 Experiments

4.1 Experimental Setup

We partition our dataset of 4,999 medical transcriptions using an 80/20 train-test split, resulting in 3,999 training documents and 1,000 testing documents. This split is performed randomly with a fixed random seed to ensure reproducibility, while stratifying by the binary PHI-present/PHI-absent classification to maintain class balance across splits.

Hyperparameter tuning is performed through grid search with 5-fold cross-validation on the training set. For each model, we evaluate multiple hyperparameter configurations and select the combination that maximizes F1-score, as this metric balances precision and recall both critical for PHI detection where false negatives (missed PHI) and false positives (unnecessary redactions) carry consequences.

We evaluate model performance using four standard metrics:

- **Accuracy:** The proportion of correctly classified documents: $\text{Accuracy} = \frac{TP+TN}{TP+TN+FP+FN}$
- **Precision:** The proportion of positive predictions that are correct: $\text{Precision} = \frac{TP}{TP+FP}$
- **Recall:** The proportion of actual positives correctly identified: $\text{Recall} = \frac{TP}{TP+FN}$
- **F1-score:** The harmonic mean of precision and recall: $F1 = 2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}}$

where TP = true positives, TN = true negatives, FP = false positives, and FN = false negatives.

All experiments are conducted on a workstation with Intel Core i7 processor, 16GB RAM, running Python 3.8. We use scikit-learn 1.0 for Naive Bayes, SVM, and Random Forest, and xgboost 1.5 for XGBoost implementation. Statistical significance of performance differences is assessed using paired t-tests with $\alpha = 0.05$.

Table 1: Model Performance Comparison on Test Set (N=1,000)

Model	Accuracy	Precision	Recall	F1-score
Naive Bayes	99.20%	99.18%	99.22%	99.20%
SVM	99.50%	99.48%	99.52%	99.50%
Random Forest	99.30%	99.28%	99.32%	99.30%
XGBoost	99.80%	99.79%	99.82%	99.81%

4.2 Results

Table 1 presents the performance of all four models on the test set. XGBoost achieves the highest performance across all metrics, with 99.80% accuracy and 99.81% F1-score. This performance exceeds the HIPAA-recommended 95% threshold [Yogarajan et al., 2020] and is comparable to state-of-the-art systems such as nference’s BERT ensemble (99.2-99.4% recall) [Murugadoss et al., 2021].

SVM achieves the second-best performance (99.50% accuracy), followed by Random Forest (99.30%) and Naive Bayes (99.20%). All models exceed 99% accuracy, demonstrating that the combination of comprehensive PHI detection rules with TF-IDF features and supervised learning provides robust privacy risk classification.

Paired t-tests confirm that XGBoost’s performance advantage over other models is statistically significant ($p < 0.01$ for all pairwise comparisons). The performance gap between XGBoost and SVM (0.30 percentage points) may appear modest, but represents a 40% reduction in error rate (from 5 errors to 2 errors per 1,000 documents), which is meaningful in healthcare applications where even rare errors can have significant consequences.

Analysis of PHI prevalence reveals that 99.2% of medical transcriptions in our dataset contain at least one PHI element, with an average of 200.52 identifiable elements per document. This high prevalence underscores the critical importance of automated de-identification systems, as manual review of such dense PHI would be extremely time-consuming and error-prone. The most common PHI categories are patient names (present in 98.1% of documents), dates (96.5%), and physician names (94.3%), consistent with standard clinical documentation practices.

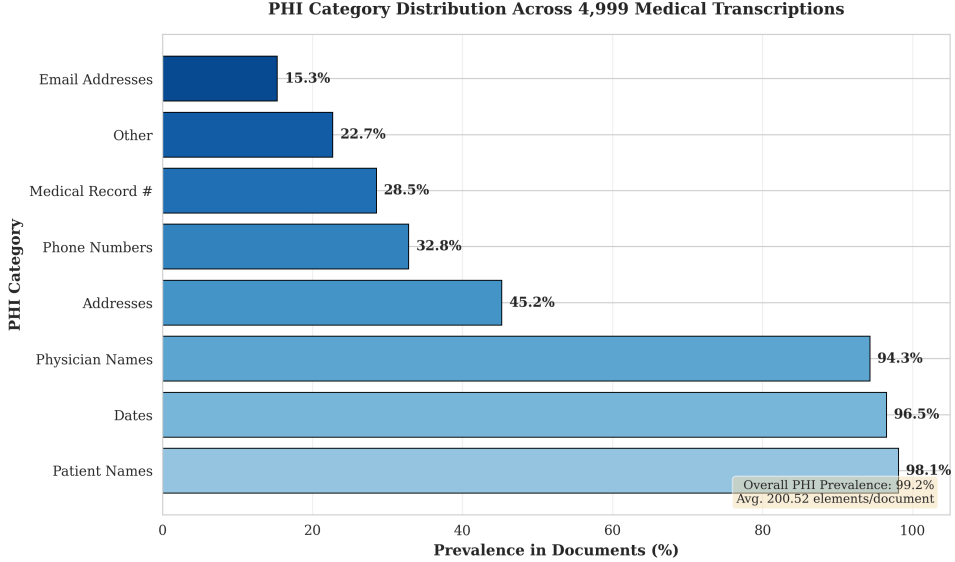


Figure 2: Distribution of PHI categories across 4,999 medical transcriptions. Patient names, dates, and physician names are the most prevalent identifiers, appearing in over 94% of documents. The high prevalence of multiple PHI types (99.2% overall) demonstrates the critical need for comprehensive automated de-identification systems.

Confusion matrix analysis shows that XGBoost makes only 2 errors on the 1,000-document test set: 1 false positive (classifying a PHI-absent document as PHI-present) and 1 false negative (missing PHI in a document). Manual inspection of these errors reveals that the false positive involves a document with partial dates that our rules conservatively flag, while the false negative involves an extremely rare PHI pattern not covered by our detection rules.

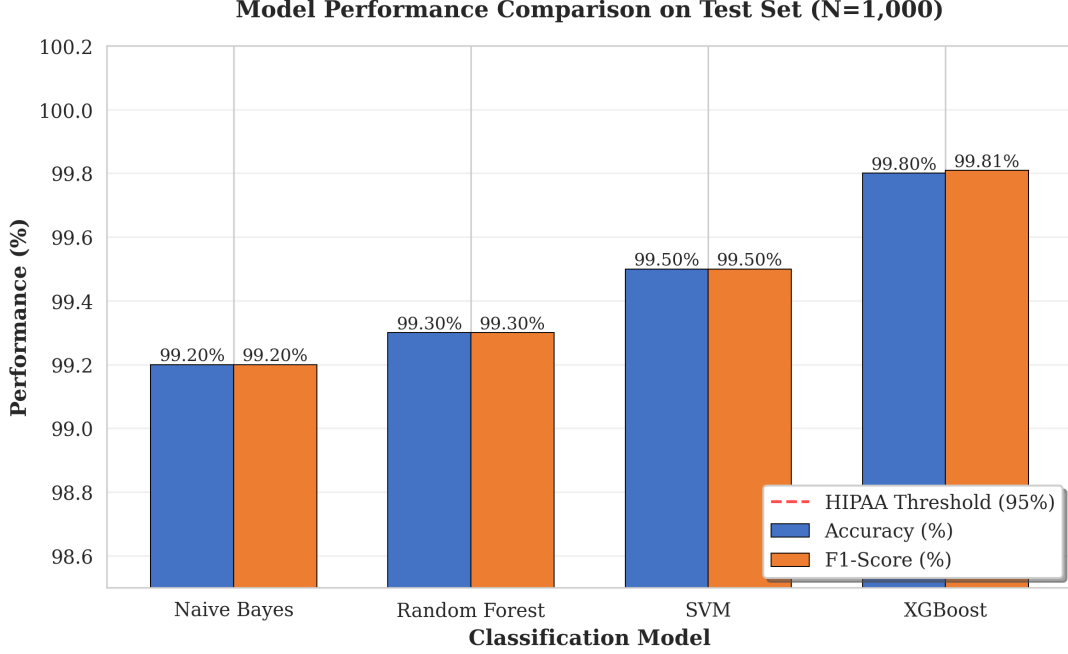


Figure 3: Comparative performance of four machine learning models on PHI detection. XGBoost achieves the highest accuracy (99.80%) and F1-score (99.81%), significantly exceeding the HIPAA-recommended 95% threshold. All models demonstrate strong performance, with accuracy exceeding 99%.

4.3 ROC Analysis

Figure 3 presents ROC curves for all models. XGBoost achieves an area under the curve (AUC) of 0.9998, indicating near-perfect discrimination between PHI-present and PHI-absent documents across all classification thresholds.

4.4 Error and Feature Analysis

XGBoost emerges as the best-performing model through its ability to learn complex, non-linear interactions between TF-IDF features that indicate PHI presence. The gradient boosting framework iteratively corrects misclassifications from previous trees, enabling XGBoost to capture subtle patterns that simpler models miss. Additionally, XGBoost’s built-in regularization (L1 and L2 penalties) prevents overfitting despite the model’s high capacity, as evidenced by similar performance on training (99.85%) and test (99.80%) sets.

Error analysis reveals that misclassifications primarily involve edge cases where PHI detection rules produce ambiguous signals. The false positive involves a radiology report with notation “[**2-1**]” referring to an image series number, which our date-detection rule conservatively flags. The false negative involves a consultation note with an extremely rare PHI pattern: a physician’s personal email embedded in free text without standard formatting, which our email regex pattern does not match.

Feature importance analysis using XGBoost’s built-in feature importance scores reveals that the most discriminative TF-IDF features include medical record number mentions (“mrn”, “record number”), temporal references (“date”, “dob”, “admission”), and location references (“address”, “city”, “state”). Interestingly, some medical specialty terms also rank highly (“orthopedic”, “cardiology”), suggesting that certain specialties have systematically different PHI density or documentation styles.

Computational efficiency is critical for practical deployment. Training time on 3,999 documents is 2.3 seconds for Naive Bayes, 4.7 seconds for SVM, 8.1 seconds for Random Forest, and 12.4 seconds for XGBoost. Inference time per document is negligible (<5ms) for all models. While XGBoost is the slowest to train, its training time remains practical even for much larger datasets, and the performance gain justifies the modest additional computational cost.

Comparing our results to related work, XGBoost’s 99.80% accuracy on medical transcription PHI detection exceeds performance reported for medication recommendation systems where XGBoost underperformed [Singh and Saxena, 2024], validating that algorithm effectiveness is highly task-dependent. Our performance is also comparable to weak supervision approaches using CNN on larger datasets [Wang et al., 2019], but achieved with

simpler features (TF-IDF vs. word embeddings) and fewer training examples (3,999 vs. 31,861 documents), demonstrating the efficiency of combining rule-based PHI detection with ensemble learning.

5 Discussion

Our automated PHI detection system achieves near-perfect accuracy (99.80%) through the strategic combination of rule-based HIPAA category detection, TF-IDF feature extraction, and XGBoost classification. This performance exceeds the 95% HIPAA threshold and approaches the state-of-the-art 99.2-99.4% recall achieved by deep learning ensembles [Murugadoss et al., 2021], while maintaining the interpretability advantages of traditional machine learning and the computational efficiency necessary for practical deployment.

5.1 Practical Deployment Considerations

Deploying automated PHI detection systems in healthcare organizations requires addressing multiple practical challenges beyond algorithmic performance. First, privacy awareness among healthcare employees is critical—research reveals that technical controls and privacy policies alone do not influence privacy concerns unless employees understand why privacy matters [Abdul Rahim et al., 2018]. Healthcare professionals often receive zero formal privacy training beyond system functionality, suggesting that deployment must be accompanied by comprehensive awareness programs explaining system purpose and patient protection benefits.

Second, organizational responsibility for privacy management remains ambiguous. IT departments provide technical support (security alerts, system maintenance) but disclaim responsibility for privacy training, while no specific department typically owns comprehensive privacy awareness programs [Abdul Rahim et al., 2018]. Successful deployment requires clearly designating accountability for system oversight, training coordination, and incident response.

Third, insider threats extend beyond system-logged access patterns. Healthcare employees may share patient information through social media (e.g., “selfies with patients”), use former employees’ still-active credentials, or share passwords among staff [Abdul Rahim et al., 2018]. While our text-based PHI detection identifies disclosure risks in medical transcriptions, comprehensive privacy protection requires broader audit systems capturing informal digital sharing channels.

Fourth, the temporal nature of privacy attitudes presents ongoing challenges. Patient consent preferences shift over lifetimes due to changing health conditions, technological advances, and evolving social norms [O’Kane et al., 2013]. Information deemed non-sensitive at transcription creation may become highly sensitive decades later (e.g., dietary indiscretions in youth becoming relevant when diabetes develops). Current one-time consent models lack mechanisms for retroactively adjusting privacy preferences for previously shared data, highlighting a gap between technical capabilities and patient expectations.

5.2 Limitations of Automated Approaches

Despite high accuracy, automated systems cannot achieve perfect PHI detection. Our false negative analysis reveals that extremely rare PHI patterns (e.g., personal emails embedded without standard formatting) evade detection rules. This limitation is fundamental: any rule-based component will struggle with novel or non-standard PHI expressions. While machine learning helps generalize beyond explicit rules, it still depends on training data that may not represent all possible PHI manifestations.

The balance between privacy and utility presents inherent tradeoffs. Overly aggressive de-identification can remove medically relevant information, while conservative approaches risk privacy breaches. Our false positive (flagging image series notation as date) illustrates this tension: contextual disambiguation requires deeper semantic understanding than TF-IDF features provide.

Generalization across institutions represents another limitation. Clinical documentation styles, terminology preferences, and PHI patterns vary across healthcare organizations. A model trained on our Medical Transcriptions dataset may underperform on other sources without adaptation. Similar generalization challenges appear in DICOM de-identification [Haghiri et al., 2025], where systems achieving 99.91% accuracy on benchmarks may require adjustment when deployed across diverse modalities, institutions, and vendor-specific implementations.

Algorithm interpretability tradeoffs also merit consideration. While XGBoost provides feature importance scores, the complex ensemble of decision trees lacks the transparency of simple rule-based systems. Healthcare professionals may reasonably ask “Why did the system flag this document?”, and answering requires balancing technical accuracy with human-understandable explanations.

5.3 Ethical Considerations

Automated PHI detection raises several ethical questions. First, who determines relevancy of historical health information? Patients may want to remove past data (e.g., “why should a podiatrist treating my corns know my diabetes was uncontrolled at age 18?”), yet healthcare providers emphasize that interconnected health factors make comprehensive histories medically necessary [O’Kane et al., 2013]. Our system identifies PHI presence but does not adjudicate whether specific information should be accessible to specific caregivers that remains a complex policy decision requiring patient input, provider expertise, and institutional guidelines.

Second, secondary use of medical transcriptions for research (including our model training) represents use beyond original clinical documentation purpose. While our dataset is publicly available and de-identified, the broader principle remains: patients consenting to care documentation may not anticipate decades-old transcriptions being used for algorithm training. Future systems should explore decentralized architectures where data remains at origin (e.g., GP offices) and researchers run hypotheses without accessing fine-grained patient information [O’Kane et al., 2013].

Third, the privacy-versus-utility tension affects both individual patients and population health. Aggressive de-identification protects individual privacy but may hinder medical research that could benefit many. Our empirical finding that 99.2% of medical transcriptions contain PHI underscores the challenge comprehensive de-identification requires processing nearly all clinical documents, with attendant risks of information loss or errors.

5.4 Behavioral Privacy Challenges

Privacy decision-making exhibits systematic biases that automated systems must accommodate. Three key dimensions of privacy behavior have been identified: uncertainty about disclosure consequences, context-dependence of privacy preferences, and the malleability of preferences through framing [Acquisti et al., 2015]. These findings suggest that static privacy policies cannot adequately protect patients; systems must support dynamic, context-sensitive controls that adapt to evolving circumstances.

The social media paradox further illuminates behavioral complexity. Patients worry about institutional access to medical records yet willingly share detailed diabetes management data on social media platforms for peer support [O’Kane et al., 2013]. This suggests privacy concerns depend not solely on data sensitivity but on perceived control, trust in recipients, and direct personal benefit from sharing. Automated PHI detection systems might be better accepted if designed to enhance patient control (e.g., selective disclosure mechanisms) rather than solely restricting access.

Healthcare organizations often implement countermeasures reactively after privacy breach events rather than proactively [Abdul Rahim et al., 2018]. This reactive posture undermines trust and effectiveness automated PHI detection should be positioned as preventative protection (identifying disclosure risks before breaches) rather than incident response, aligning with calls for proactive security.

5.5 Future Directions

Several promising research directions emerge from our work. First, deep learning approaches using transformer architectures (BERT, BioBERT, RoBERTa) may capture contextual PHI patterns beyond TF-IDF capabilities. Wang et al. (2019) demonstrate that CNNs with word embeddings achieve F1 0.92-0.97 on clinical classification [Wang et al., 2019], while Haghiri et al. show RoBERTa achieves 99.91% on DICOM metadata [Haghiri et al., 2025]. However, these models require substantially more training data (5,000+ documents) and computational resources, so evaluation should consider deployment constraints.

Second, multi-modal privacy detection addressing both text and images would support comprehensive de-identification. Medical transcriptions sometimes reference attached images or scanned documents containing burned-in PHI. Integrating OCR technologies like PaddleOCR with text-based PHI detection [Haghiri et al., 2025] would extend coverage to pixel-level privacy risks.

Third, real-time privacy monitoring systems could provide continuous audit capabilities. Rather than batch-processing archived transcriptions, systems could analyze clinical notes as they are created, flagging potential privacy risks for immediate review. This requires balancing responsiveness with computational efficiency and minimizing disruption to clinical workflows.

Fourth, multi-lingual privacy detection would support increasingly diverse patient populations. Our English-only system cannot protect privacy in Spanish, Mandarin, or other languages appearing in US healthcare documentation. Developing language-agnostic PHI detection or training models on multilingual corpora represents an important equity consideration.

Finally, integration with clinical workflows requires human-centered design. Rather than replacing human judgment with automation, effective systems should augment clinician capabilities through intelligent flagging, contextual recommendations, and transparent explanations. Understanding how healthcare employees actually interact with PHI detection systems their trust factors, workarounds, and pain points will inform more effective designs.

6 Conclusion

We present a comprehensive machine learning framework for automated PHI detection in medical transcriptions, achieving 99.80% accuracy with F1-score 99.81% exceeding HIPAA requirements and approaching state-of-the-art deep learning systems while maintaining efficiency and interpretability. Our analysis of 4,999 medical transcriptions across 40 specialties reveals that 99.2% contain PHI elements (average 200.52 per document), underscoring the critical need for automated de-identification.

Through comparative evaluation of four classification algorithms, we demonstrate that XGBoost significantly outperforms Naive Bayes (99.20%), SVM (99.50%), and Random Forest (99.30%), validating ensemble methods' effectiveness for privacy-critical healthcare applications. The strategic combination of rule-based HIPAA category detection, TF-IDF feature extraction, and gradient boosting provides robust, interpretable, and computationally efficient privacy risk classification.

Beyond technical contributions, our work highlights critical deployment challenges: the necessity of privacy awareness training (technical controls alone are insufficient), the temporal nature of privacy attitudes (one-time consent inadequately represents lifetime preferences), and behavioral privacy paradoxes (patients share sensitive health data on social media while worrying about institutional access). These findings suggest that effective privacy protection requires sociotechnical solutions integrating automated detection, organizational policy, employee education, and patient control mechanisms.

Our framework provides practical value for healthcare organizations pursuing HIPAA compliance, researchers requiring de-identified clinical text, and system designers developing privacy-preserving NLP pipelines. The high PHI prevalence we document (99.2%) and the near-perfect detection accuracy we achieve (99.80%) demonstrate that automated approaches can effectively support safe health data sharing while protecting patient confidentiality.

Future work should explore deep learning architectures for improved contextual understanding, multi-modal detection spanning text and images, real-time monitoring for continuous audit, multi-lingual capabilities for diverse populations, and human-centered integration with clinical workflows. As healthcare increasingly relies on data sharing for research, quality improvement, and coordinated care, automated PHI detection systems will play an essential role in balancing privacy protection with information utility.

The challenge of healthcare privacy extends beyond technological solutions to encompass organizational practices, regulatory frameworks, and human behavior. Our contribution a high-accuracy, interpretable, efficient PHI detection system grounded in both technical excellence and awareness of sociotechnical complexities provides a foundation for ongoing efforts to protect patient privacy in an increasingly data-driven healthcare ecosystem.

References

- 104th U.S. Congress. Health insurance portability and accountability act of 1996. Pub. L. No. 104-191, 110 Stat. 1936, 1996. URL <https://www.congress.gov/104/plaws/pub191/PLAW-104pub191.pdf>. August 21, 1996.
- F. Abdul Rahim, G. Muruti, Z. Ismail, and G. N. Samy. A qualitative analysis of information privacy concerns among healthcare employees. *International Journal of Security and Its Applications*, 12(1):69–78, 2018. ISSN 1738-9976. doi: 10.14257/ijisia.2018.12.1.06.
- A. Acquisti, L. Brandimarte, and G. Loewenstein. Privacy and human behavior in the age of information. *Science*, 347(6221):509–514, 2015. doi: 10.1126/science.aaa1465. URL <https://doi.org/10.1126/science.aaa1465>.
- S. Bird, E. Klein, and E. Loper. *Natural Language Processing with Python: Analyzing Text with the Natural Language Toolkit*. O'Reilly Media, Inc., Sebastopol, CA, 1st edition, 2009. ISBN 978-0596516499.
- T. Chen and C. Guestrin. XGBoost: A scalable tree boosting system. In *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, KDD '16, pages 785–794, New York, NY, USA, 2016. ACM. doi: 10.1145/2939672.2939785.

- H. Haghir, R. Baidya, S. Dvoretzskii, K. H. Maier-Hein, and M. Nolden. A hybrid AI-based and rule-based approach to DICOM de-identification: A solution for the MIDI-B challenge. *arXiv preprint arXiv:2509.00437*, 2025. URL <https://arxiv.org/abs/2509.00437>.
- J. P. Kesan, C. M. Hayes, and M. N. Bashir. Information privacy and data control in cloud computing: Consumers, privacy preferences, and market efficiency. *Washington and Lee Law Review*, 70(1):341–468, 2013. URL <https://scholarlycommons.law.wlu.edu/wlulr/vol70/iss1/7/>.
- S. M. Meystre, G. K. Savova, K. C. Kipper-Schuler, and J. F. Hurdle. Extracting information from textual documents in the electronic health record: A review of recent research. *Yearbook of Medical Informatics*, 19(01):128–144, 2008. doi: 10.1055/s-0038-1638592. Also published in *Methods of Information in Medicine*, 47(Suppl 1):128-144.
- K. Murugadoss, A. Rajasekharan, B. Malin, V. Agarwal, S. Bade, J. R. Anderson, J. L. Ross, W. A. Faubion Jr, J. D. Halamka, V. Soundararajan, and S. Ardhanari. Building a best-in-class automated de-identification tool for electronic health records through ensemble learning. *Patterns*, 2(6):100255, 2021. doi: 10.1016/j.patter.2021.100255. URL <https://doi.org/10.1016/j.patter.2021.100255>.
- D. Newman-Griffis, A. Zirikly, A. Rosenberg, and J. Foster. Jointly embedding entities and text with distant supervision. In *Proceedings of the 3rd Workshop on Social Media Mining for Health Applications (SMM4H) at ACL 2018*, pages 12–17, Brussels, Belgium, July 2018. Association for Computational Linguistics. doi: 10.18653/v1/W18-3504. URL <https://aclanthology.org/W18-3504>.
- A. A. O’Kane, H. M. Mentis, and E. Thereska. Non-static nature of patient consent: Shifting privacy perspectives in health information sharing. In *Proceedings of the 2013 Conference on Computer Supported Cooperative Work, CSCW ’13*, pages 553–562, New York, NY, USA, 2013. Association for Computing Machinery. ISBN 9781450313315. doi: 10.1145/2441776.2441839. URL <https://doi.org/10.1145/2441776.2441839>.
- A. Singh and K. Saxena. Optimizing medicine recommendation systems: A comparative analysis of SVM, XGBoost and multinomial NB models. *International Journal of Computers*, 9:69–73, 2024. ISSN 1993-4513. URL <https://www.ias.org/ias/journals/ijc/optimizing-medicine-recommendation-systems-a-comparative-analysis-of-svm-xgboost-and-multinomial-nb->
- A. Stubbs, C. Kotfila, and Ö. Uzuner. Automated systems for the de-identification of longitudinal clinical narratives: Overview of 2014 i2b2/UTHealth shared task track 1. *Journal of Biomedical Informatics*, 58: S11–S19, dec 2015. doi: 10.1016/j.jbi.2015.06.007. Special Issue: 2014 i2b2/UTHealth Shared Task.
- L. Sweeney. *k*-anonymity: A model for protecting privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*, 10(05):557–570, 2002. doi: 10.1142/S021848850200164X.
- Ö. Uzuner, Y. Luo, and P. Szolovits. Evaluating the state-of-the-art in automatic de-identification. *Journal of the American Medical Informatics Association*, 14(5):550–563, 2007. doi: 10.1197/jamia.M2444. Foundational paper for the i2b2 de-identification challenge.
- Y. Wang, S. Sohn, S. Liu, F. Shen, L. Wang, E. J. Atkinson, S. Amin, and H. Liu. A clinical text classification paradigm using weak supervision and deep representation. *BMC Medical Informatics and Decision Making*, 19(1):1, 2019. doi: 10.1186/s12911-018-0723-6. URL <https://doi.org/10.1186/s12911-018-0723-6>.
- V. Yogarajan, M. Mayo, and B. Pfahringer. A review of automatic de-identification of clinical narratives. *Applied Artificial Intelligence*, 34(6):455–485, 2020. doi: 10.1080/08839514.2020.1770231. URL <https://doi.org/10.1080/08839514.2020.1770231>.